Shodan Dorking Safe Guide

Educational Bug Bounty Series • Authorized Security Research Only

■ Shodan Dorking — Authorized Asset Discovery

Contributed by Cyber_Spy.404 | Bug Bounty Notes

Critical safety note: *Internet-wide search results can include hospitals, industrial controls, cameras, routers, remote-access services, and other sensitive systems. Search and test only assets explicitly authorized by the program; never attempt access or interaction with critical infrastructure.*

■ Executive Summary

The source HTML, *shodan.html*, groups Shodan filters and examples into basic filters, web services, databases, industrial control systems (ICS), remote desktop, network infrastructure, Outlook Web Access, NAS, webcams, printers/copiers, home devices, and miscellaneous systems. Many source examples identify exposed or weakly protected services. This guide retains the categories and basic filter concepts while omitting actionable query strings that target vulnerable critical infrastructure or unauthenticated devices.

■ Core Testing Methodology

1. Confirm the exact in-scope domain, IP, ASN, and any excluded ranges.
2. Begin with the least intrusive search filters and use them only to locate assets already authorized for assessment.
3. Treat banners and product labels as indicators, not proof of a vulnerability or current exposure.
4. Verify versions and exposure through vendor documentation or owner-approved checks.
5. Do not log in, interact with control panels, change settings, send commands, or access data.
6. For critical infrastructure and medical/industrial devices, report passive observations and seek program guidance before any further validation.
7. Keep screenshots and output redacted; do not publish device locations, credentials, or personal information.

■ High-Value Tips & Edge Cases

Basic filter concepts present in the source

- `hostname:` — hostname filter
- `net:` — IP address or CIDR network
- `org:` — organization label
- `asn:` — Autonomous System Number
- `country:` / `city:` / `geo:` — location-related filters
- `port:` — port number
- `product:` / `os:` / `device:` — product, operating system, or device classification
- `server:` — server banner
- `ssl.cert.*` — certificate attributes
- `before:` / `after:` — time filters

Safe template: use a verified, authorized asset value rather than a broad city, country, device, or product query.

```
hostname:YOUR-AUTHORIZED-DOMAIN.example
net:YOUR-APPROVED-CIDR
org:"YOUR-ORGANIZATION"
```

These are templates; replace them only with values explicitly included in the program scope.

Source categories preserved

- **Basic Shodan filters:** city, country, geographic coordinates, hostname, network, organization, ASN, OS, port, time, TLS certificates, device type, product, CPE, server, SSH fingerprints.
- **Web-related services:** VPN/web gateways and certificate/file-index indicators.
- **Databases:** MySQL, MongoDB, Elasticsearch, Memcached, CouchDB, PostgreSQL, Riak, Redis, Cassandra.
- **Industrial control systems (ICS):** billboards, fuel systems, traffic systems, voting systems, energy generation/meters, building automation, access controllers, rail systems, and industrial protocols including Modbus, BACnet, DNP3, EtherNet/IP, S7, and others.
- **Remote desktop:** VNC and RDP.
- **Network infrastructure:** routers, Redis, Citrix, Kubernetes/Docker-related dashboards/APIs, Jenkins, DNS, Telnet, video conferencing, management interfaces, and known historical CVEs.
- **OWA and collaboration:** Exchange and Lync/Skype for Business.
- **NAS and file services:** SMB, FTP, NAS products, media servers, and attached storage.
- **Webcams:** camera/webcam products and surveillance systems.
- **Printers/copiers:** HP, Xerox, Epson, Canon.
- **Home devices:** audio receivers, AirPlay, smart TVs/Chromecast, smart-home controllers.
- **Miscellaneous:** 3D-printer controllers, mining systems, directory listings, WordPress, game servers, and other internet-facing services.

■■ Educational Checklist & Safe Examples

```
Program: [Program Name]
Authorized asset: [Exact Host/IP/CIDR]
Shodan filter: [Scope-bound filter]
Observation: [Banner/version, no sensitive data]
Vendor advisory checked: [Yes/No]
Active validation permitted: [Yes/No]
Finding status: [Lead / Confirmed / Inconclusive]
Evidence: [Redacted]
```

- [ ] Exact scope confirmed
- [ ] No broad searches for critical infrastructure or private devices
- [ ] No authentication attempts or interaction with exposed systems
- [ ] Version/banner evidence treated cautiously
- [ ] Vendor advisories checked
- [ ] Evidence redacted and minimally retained

■■ Mitigation & Remediation

Remove unnecessary public exposure, restrict management interfaces by network policy, require strong authentication and MFA, patch firmware and services, disable unused protocols, segment OT/ICS from the public internet, monitor asset exposure, and follow vendor-specific hardening guidance. Critical infrastructure should use defense-in-depth and strict network segmentation.

■ Source Notes

Based on *shodan.html*. The source has sections for basic filters, web services, databases, ICS, remote desktop, network infrastructure, OWA, NAS, webcams, printers/copiers, home devices, and miscellaneous systems. It includes numerous searches for unauthenticated or sensitive devices; the operational query strings are intentionally not reproduced. The original examples may be outdated and should not be treated as proof of present-day exposure.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.